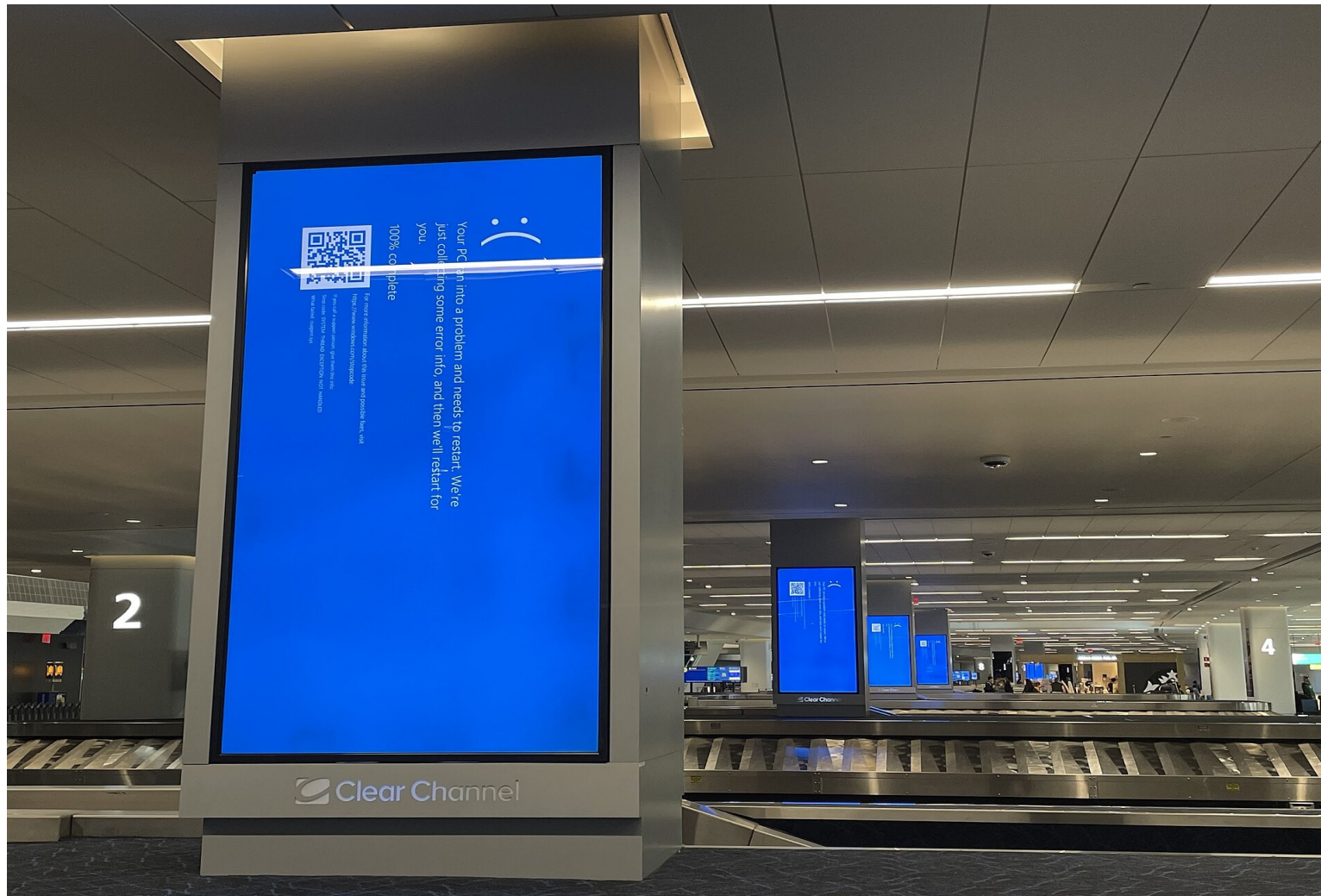




BSOD на табло аэропорта LaGuardia, Нью-Йорк · 19.07.2024 · Wikimedia · CC-BY-SA

**Один файл.
8,5 миллиона
устройств.**

**Не атака.
Автоматический
деплой.**

19 июля 2024, 04:09 UTC.

CrowdStrike разворачивает обновлённый Falcon channel file — это конфиг, не код.

За часы — мировой каскад BSOD.

Delta отменила 7 000 рейсов.

Совокупный ущерб — более 5 миллиардов долларов.

Где на лестнице автономии AI этот сбой произошёл? Что нужно знать инженеру, чтобы не повторить?

14

Лекция 14

AI в телекоммуникациях, сетевой инфраструктуре и кибербезопасности

Модуль 3 · 75 минут + Q&A

Студенты-инженеры 3 курса · универсальная программа

Центральный вопрос:

Где AI работает в телекоме/инфре/cyber, где может остановить аэропорт, и какие три вопроса нужно задать вендору?

Видит → Решает → Действует.

Где AI помогает, а где может остановить аэропорт. Чем выше — тем больше масштаб поражения при ошибке.

Все каскадные сбои 2024–2025 — на верхнем уровне: CrowdStrike, Cloudflare, AWS, Azure, Replit			
	Телеком	AIOps	Кибербезопасность
ДЕЙСТВУЕТ <i>пиковый риск</i>	xApps авто-настройка, авто-биллинг 	Авто-исправление, обновления ядра 	SOAR авто-блок, изоляция EDR 
РЕШАЕТ <i>средний риск</i>	SON-корреляция, клиентский LLM	LLM-сценарии (Claude SRE)	Charlotte/Copilot триаж алертов
ВИДИТ <i>низкий риск</i>	rApps RIC телеметрия	Datadog/Dynatrace аномалии	SIEM ML-детекция

Рабочий термин для лекции · канонические опоры: Parasuraman & Sheridan (2000), SAE J3016, Endsley.
Это не OODA — OODA — петля внутри миссии. Наша лестница — таксономия по масштабу поражения при ошибке.
Внимание: вендор может продавать LLM как «наблюдатель», а под капотом — автоматическое действие. Спрашивайте, где затвор между уровнями.

Маршрут лекции — пять разделов

1

Телеком

Стек оператора · AI-RAN ·
клиентский LLM · Klarna / Air
Canada · вопросы
поставщику

2

AIOps

Лестница в действии ·
CrowdStrike · Cloudflare ·
математика Байеса ·
усталость от алертов

3

Кибербезопасность

AI для защиты · AI как
оружие · AI как мишень ·
MITRE ATLAS

4

Рамка

Сводная таблица 3×3 · 6
критериев · 5-шаговая рамка
· разбор SOAR

5

Замыкание

Подведение итогов ·
следующая лекция · вопросы

Пять терминов «обязательно знать» — остальные расшифровываются inline

Масштаб поражения

масштаб ущерба
при ошибке автоматизации

Дрейф

распределение данных
уходит от обучающего

Prompt injection

скрытая инструкция
в входных данных для LLM

Человек в контуре

(HITL)
human-in-the-loop
человек принимает решение

Канарейка

деплой на 1% перед 100% —
страховка от каскада

Полная лестница автономии — на следующем слайде. Распечатайте — пригодится через год на стажировке.

Стек оператора связи: AI входит на каждый уровень с разным масштабом ошибки

Сверху вниз: RAN (радио) → ядро сети → BSS/OSS (биллинг + поддержка) → абонент

RAN — радиосеть

Сотовые вышки · NVIDIA-SoftBank AITRAS · Rakuten Symphony RIC

АВТОНОМИЯ

Видит → Решает → Действует (xApps)

Ядро сети (core)

5G core · network slicing · политики QoS

АВТОНОМИЯ

Видит → Решает

BSS/OSS — биллинг + операции

Vodafone TOBi · Telefónica AURA · DT RAN Guardian

АВТОНОМИЯ

Видит → Решает (клиентский LLM)

Абонент

Клиентский LLM · персонализация · поддержка 24/7

АВТОНОМИЯ

Видит → Решает (НЕ Действует)

RAN xApps могут «действовать» в миллисекундном цикле. Клиентский LLM «решает», но финальное действие — за человеком.

Open RAN отделяет мозг (RIC) от железа. Два темпа автономии: rApps минуты, xApps миллисекунды.

AI-RAN — оптимизация радиосети моделями. Реальные внедрения 2024–2025: NVIDIA-SoftBank, Rakuten, Nokia, Ericsson



Базовая станция — Wikimedia CC-BY-SA



Nokia HQ Espoo — Wikimedia CC-BY-SA

СЛОВАРЬ AI-RAN

Open RAN

Открытая архитектура радиосети — модули от разных вендоров, не один проприетарный комплекс.

RIC

RAN Intelligent Controller — центральный мозг Open RAN, отделённый от железа.

rApps

Приложения на non-real-time RIC, цикл — минуты. Долгосрочная оптимизация.

xApps

Приложения на near-real-time RIC, цикл — миллисекунды. Управление в реальном времени.

Adoption-карта 2024–2025 — «Видит → Решает» уровни

· NVIDIA-SoftBank AITRAS · общенациональная AI-RAN

· Rakuten Symphony · RIC в проде, Япония

· Nokia AVA + KDDI · цифровой двойник сети

· Ericsson EIAP · единая платформа AI

· Samsung-KT-SK Telecom · корейская кооперация

Клиентский LLM — три промышленные эксплуатации

Vodafone TOBi · Telefónica AURA · Verizon Gemini — голосовая и текстовая поддержка абонентов

Vodafone TOBi

Великобритания + ещё 14 рынков

- Чат-бот для абонентов
- Goldman Sachs: ~30% запросов закрываются без оператора
- Эволюция в SuperTOBi 2025

Анти-кейс — Италия (см. далее)

Telefónica AURA

Испания + 6 стран

- Голосовой помощник в 6 странах
- ~400 млн разговоров в год
- Интеграция в личный кабинет

Утверждения поставщика

Verizon Gemini

США

- Партнёрство с Google Cloud 2024
- Поддержка операторов колл-центра
- RAG по базе обращений

Дополнение оператора, не автономия

Три типа провала customer-AI — три урока

Бизнес-разворот · юридическая ответственность · деградация качества

Klarna

Klarna

Klarna · логотип компании

февраль 2024 → май 2025

БИЗНЕС-РАЗВОРОТ

- Февраль 2024: AI-ассистент «делает работу 700 человек»
- Май 2025: «качество упало» — возвращают людей
- Один год — полный круг

Урок: Полностью автономный AI на финальном решении — экономика не сошлась.

Air Canada



Air Canada · Wikimedia CC-BY-SA

февраль 2024

ЮРИДИЧЕСКАЯ ОТВЕТСТВЕННОСТЬ

- Чат-бот пообещал скидку по тарифу bereavement (соболезнования)
- Суд Британской Колумбии: компания отвечает за слова бота
- Прецедент: \$812 + бессрочный

Урок: Утверждение «AI всего лишь инструмент» не освобождает компанию от ответственности.

Vodafone Italy

2023 → 2024

ДЕГРАДАЦИЯ UX

- SuperTOBi → жалобы пользователей
- Индекс лояльности (NPS) упал
- Откат к гибриду AI + люди

Урок: Полностью автономный клиентский AI ≠ безопасность UX. NPS — сторожевая метрика.

Общий вывод: гибрид AI + люди выигрывает у полностью автономного клиентского AI на финальном решении

Три вопроса вендору — для ЛЮБОГО AI-предложения

Заякорьте сейчас. Через год на стажировке начальник предложит «давайте включим» — задайте именно эти три.

1

Базовый уровень

Какими были MTTD (среднее время до обнаружения), MTTR (среднее время до восстановления) и пропускная способность ДО внедрения AI?

Без базового уровня любая цифра — это маркетинговая метрика, не улучшение.

2

Окно + методология

Промышленная эксплуатация или демо?
Какие вмешательства засчитаны в метрику?

Подбор по факторам (PSM) ≠ RCT. Утверждение поставщика ≠ независимый замер.

3

Управление изменениями + канарейка

Какая процедура отката при каскаде?
Деплой на 1% перед 100%?

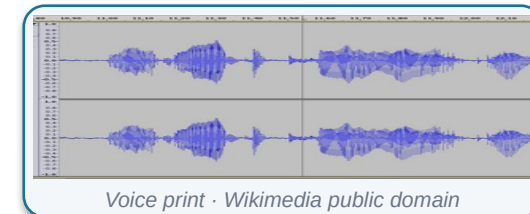
Без канареечного деплоя и отката вы будете на следующем «CrowdStrike-постере».

ОСОБОЕ ВНИМАНИЕ — скрытый «Действует»

Поставщик может продавать LLM-агента как «наблюдатель», а под капотом — автономное действие. Спрашивайте: где затвор между уровнями? Кто принимает финальное решение?

Голосовая биометрия защищала. Теперь голос сам атакован.

Subex anti-fraud · AT&T fraud detection · Pindrop voice clones · CFCA report



ЧТО РАБОТАЕТ (защита)

Subex

«150% предотвращённых потерь» — утверждение поставщика, спросить базовый уровень.

AT&T — обнаружение мошенничества

Поведенческие модели на CDR-данных (детализация звонков).

Pindrop — голосовая биометрия

Идентификация по голосу — десять лет работает в банках, колл-центрах.

Отчёт CFCA

Глобальный убыток от мошенничества в телекоме — десятки миллиардов в год.

ЧТО ПОЯВИЛОСЬ (атака)

Клонирование голоса

Pindrop 2024–2025: число попыток клонирования голоса выросло на порядок год к году.

Реальность: «голос как пароль» — больше не работает

Биометрия голоса сама стала под атакой. Нужна многофакторная проверка.

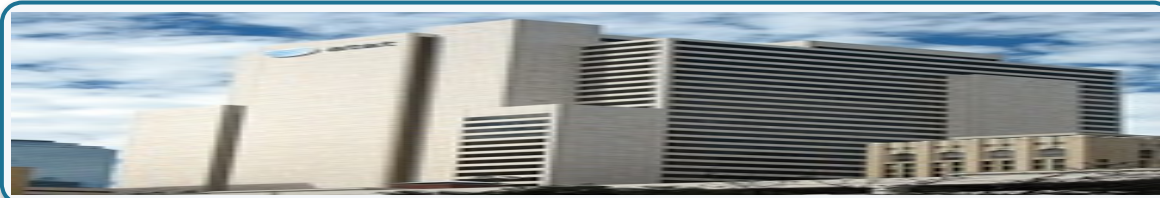
Дальше — дипфейк-CFO Arup на 25,6 млн \$

Та же технология — клонирование голоса плюс видеосинтез. Защита = изменение процесса верификации, не AI-контр-детектор.

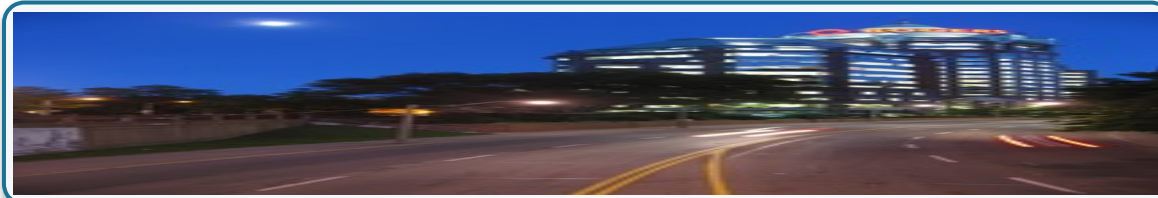
Защитная AI работает на уровне «Видит». Та же технология даёт атакующим инструменты — вернёмся к этому в разделе про кибербезопасность.

AT&T 22 февраля 2024 — это CrowdStrike-паттерн ДО CrowdStrike

Один не проверенный конфиг — 125 миллионов устройств без связи. Тот же шаблон каскадных сбоев инфры



AT&T HQ Dallas · Wikimedia CC-BY-SA



Rogers Building Toronto · Wikimedia CC-BY-SA

AT&T США

22.02.2024

12 часов простоя

- Изменение в сетевом управлении — не проверенное
- ~125 миллионов устройств без связи
- Расследование FCC: «нарушение процедур управления изменениями»
- Все экстренные вызовы (E911) частично недоступны

Урок: Конфиг ≠ код. Но автоматический деплой обращается с ним как с кодом.

Rogers Канада

08.07.2022

15+ часов простоя

- Ошибка в распространении IPv6-маршрутов
- ~10 миллионов абонентов без связи
- Платёжная система Interac упала
- CRTC: «отсутствие отказоустойчивости сети»

Урок: Единая точка отказа в конфиге — каскад через всю инфру.

ПЕРЕХОД к разделу AIOps — каскадные сбои инфры

AT&T и Rogers — это «CrowdStrike до CrowdStrike». Дальше — полная картина: четыре каскада 2024–2025 на верхнем уровне лестницы.

Когда AI НЕ нужен в телекоме — пять жёстких границ

Не вкус. Не предпочтения. Архитектурные/регуляторные/физические ограничения

E911 / E112	Биллинг	Законный перехват	URLLC	Объяснимость по EU AI Act
Маршрутизация экстренных вызовов Latency + регуляторный hardline. Недетерминированный путь = риск жизни.	Расчёт счетов абонентам Детерминированный мандат. Аудит. Любая «ошибка ML» = иск.	CALEA (США) · COPM (РФ) Регуляторный мандат. Vendor-self-claim не пройдёт аудит ФСБ/ФБР.	Ultra-reliable low-latency (промышленное 5G) Стабильность ПИД/МРС проверена 60 лет. ML вносит хвост распределения.	High-risk AI в критической инфре Аудитор спросит: «почему сеть приняла это решение?» Чёрный ящик не пройдёт.

Если хотя бы один критерий выполнен — автономный режим AI отключаем. Это не дискуссия.

Альтернативы AI в телекоме — проверенные классические инструменты

3GPP SON · инженерия трафика по Erlang · ПИД/MPC · федеративное обучение

3GPP SON

Self-Organizing Networks

Self-configure / Self-optimize / Self-heal — rule-based, сертифицированный.

Когда брать: Когда AI «улучшает» SON — спросите, что именно. SON и так работает.

Erlang traffic engineering

1909 → 2026

Erlang B/C формулы для расчёта нагрузки + Markov chains.

Когда брать: Лучшие любой ML для прогноза blocking probability — это математика, не статистика.

ПИД / MPC

Control theory — PID & Model Predictive Control

Стабильность доказана 60 лет в URLLC, power amplifiers, antenna tuning.

Когда брать: Layer-Adaptive PID + ML гибрид — выбор там, где ML только подсказывает, а PID управляет.

Federated Learning + DP

Privacy-preserving distributed

Обучение без обмена сырыми данными (Differential Privacy).

Когда брать: Compliance-friendly (GDPR, СПП). Не быстро, но проходит аудит.



РАЗДЕЛ

AIOps

Лестница автономии в действии

ДЕЙСТВУЕТ

автоисправление,
обновления ядра

→ CrowdStrike · Cloudflare · AWS · Azure

РЕШАЕТ

LLM-сценарии
(Claude SRE, NeuBird)

→ DORA paradox · Anthropic пост-мортем 23.04.2026

ВИДИТ

Dynatrace Davis,
Datadog Bits AI

→ работает в проде (низкий масштаб поражения)

AIOps уровня «Видит»: что реально работает в проде

ML на телеметрии — безопасный класс задач. Четыре вендора, документированные внедрения

-40% времени простоя Cisco ThousandEyes Kamstrup (независимо)	4 000+ корпоративных внедрений Cisco DNA Center IBN (публичный счётчик)	Тысячи enterprise развёртываний Dynatrace Davis · APM (публичный портфель)	Walmart T-Mobile крупный enterprise Splunk Mission Control (публичные внедрения)
Dynatrace Davis AI-движок APM Корреляция аномалий в телеметрии. Утверждение поставщика.	Datadog Bits AI Запросы на естественном языке Preview 2024. Естественный язык над метриками + логами.	Cisco ThousandEyes Сетевая видимость Kamstrup -40% — редкий случай независимой валидации.	Splunk Mission Control ML на безопасности и observability T-Mobile, Walmart Element — крупные внедрения.
			Урок уровня «Видит» ML над телеметрией работает. Низкий масштаб поражения — даже ложное срабатывание не останавливает прод. Безопасный вход для AI.

Уровень «Решает»: даже Anthropic делает регрессии. DORA 2025 — парадокс.

LLM-сценарии (LLM-runbooks) на инциденты + AI-coding — два самых горячих сценария 2025

Anthropic own-postmortem

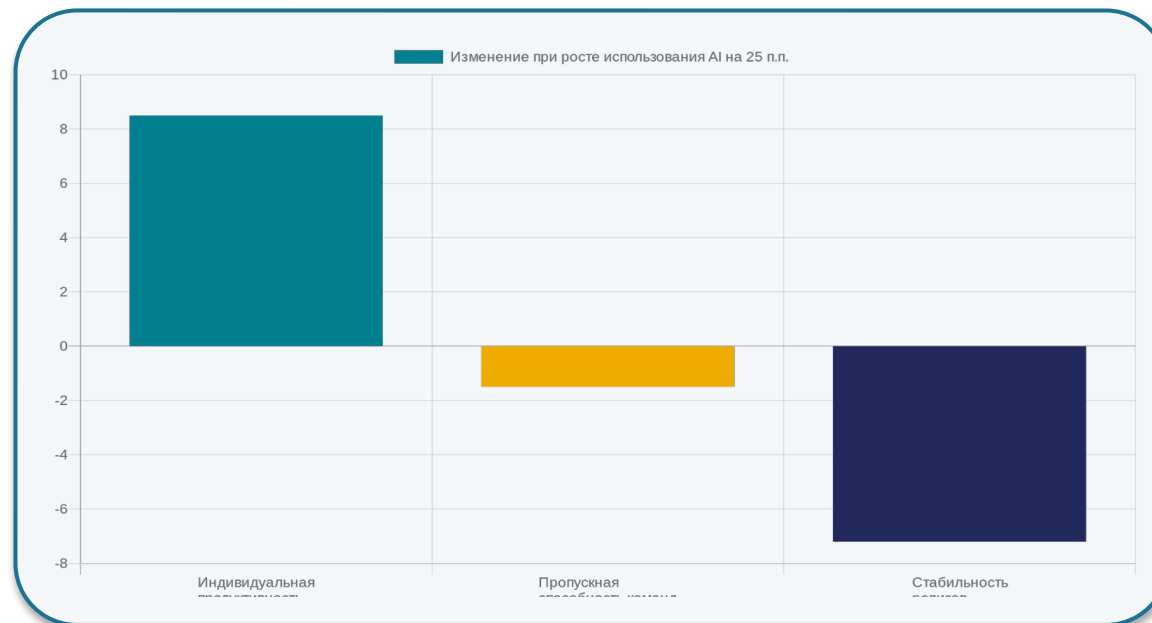
23 апреля 2026 — engineering blog post

Три перекрывающихся регрессии Claude Code

Собственный отчёт Anthropic:

«красивый 80%-ный нарратив, плохо с корневыми причинами»

Внутренние evals мирового уровня не поймали — 6 недель деградации.
Это публичный отчёт от вендора — самый честный сигнал в индустрии 2026.



Урок уровня «Решает»

1. DORA 2025: рост использования AI на 25 п.п. → индивидуальная продуктивность +8,5 п.п., но throughput команд -1,5 п.п., стабильность -7,2 п.п.
2. Anthropic публичный пост-мортем — эталон честности: «AI закрывает 80%, но в поиске корневой причины проваливается». Открытое признание вендора — самый ценный сигнал.
3. Уровень «Решает» требует человека в контуре обязательно. Без него LLM-сценарий соберёт «правдоподобный 80%-ный нарратив» — и в этих 20% живёт хвост каскада.

AI-автоматизация инфраструктуры: что работает на уровне «Действует»

Cisco DNA · Juniper Marvis · ServiceNow Control Tower · Netflix — четыре инструмента в проде

56%

инцидентов автоисправлены

Netflix

(блог компании)

4 000+

корпоративных внедрений

Cisco DNA Center IBN

(публичный счётчик)

Agentic

автономный режим

Juniper Mist Marvis Actions

(GA 2024)

Multi-tenant

оркестрация

ServiceNow Control Tower

(enterprise SaaS)

Cisco DNA Center IBN

Управление по намерениям (intent-based networking)

Декларативное намерение администратора → автоматическая трансляция в конфигурацию сети. Более 4 000 корпоративных внедрений.



Cisco HQ Сан-Хосе · Wikimedia

Juniper Mist Marvis Actions

Обеспечение качества на AI

AI собирает причину сбоя + предлагает действие; в автономном режиме сам исполняет изменение.



Juniper Networks HQ · Wikimedia

ServiceNow Control Tower

Оркестрация автоматического восстановления

Конвейер действий + LLM + интеграция с процессом управления изменениями в крупных корпорациях.

Netflix авто-исправление

Внутренний инструмент · утверждение поставщика

Заявление вендора: 56% инцидентов в эксплуатации исправляются автоматически.
Источник: Netflix Tech Blog.

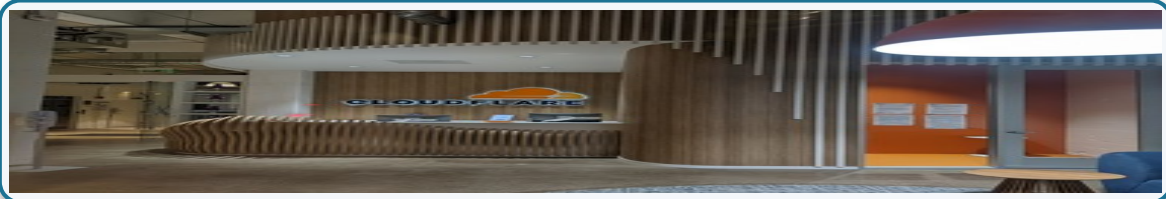
Это работает. И именно поэтому опасно.

CrowdStrike, Cloudflare, AWS, Azure, Replit — все падали на этом уровне в 2024–2025.

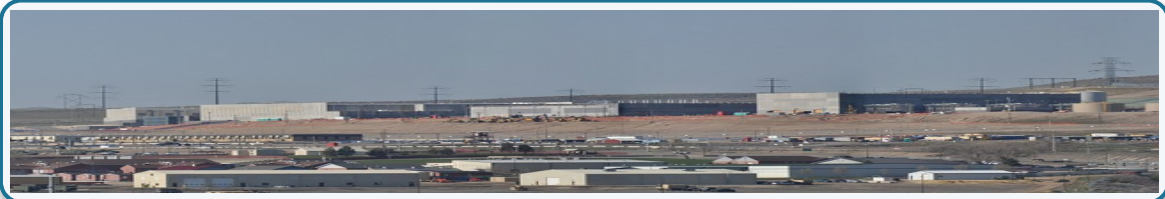
Без канареечного деплоя и процедуры отката автоматическое исправление — это снаряд по своей же инфраструктуре.

Октябрь–ноябрь 2025: три каскада за 30 дней

Cloudflare · AWS DynamoDB · Azure Front Door — все на верхнем уровне лестницы



Cloudflare HQ · San Francisco · Wikimedia CC-BY-SA



Гипермасштабный ЦОД · Wikimedia CC-BY-SA

Cloudflare

18.11.2025

5ч 38мин (core ~3ч 10мин)

- Database permission change в ClickHouse
- Дубли в feature file → превышен лимит 200 фич
- Memory limits в proxy fleet → крах Bot Management
- ChatGPT, X, Spotify, тысячи SaaS — недоступны

Не DNS. Конфиг распространился автоматически и сломал core traffic.

AWS DynamoDB

20.10.2025

~15 часов

- Deterministic race condition в DNS-автоматике
- Planner ↔ Enactor — гонка в us-east-1
- AWS post-mortem HE называет AI причиной
- Эффект: RDS, Lambda, EC2, кэши в us-east-1

Это классический сбой автоматизации, не AI. Не путать с Kiro Dec 2025.

Azure Front Door

29.10.2025

~8 часов

- Канарейка не сработала
- Сигналы canary шли через тот же сломанный слой
- Microsoft 365 + Xbox + Azure сервисы — деградация
- Пост-мортем: «слепое пятно мониторинга»

Канарейка без независимого канала наблюдения — фиктивная канарейка.

CrowdStrike 19.07.2024 — анатомия каскада

Falcon channel file (конфиг!) → крах ядра Windows → 8,5 миллиона устройств → 5+ миллиардов \$ ущерба

ТАЙМЛАЙН

04:09 UTC

CrowdStrike выкатывает Falcon channel file 291

Конфиг-файл, НЕ исполняемый код. Считается «безопасным» обновлением.

04:09–05:27

Файл загружается на все Windows-устройства

Без канарейки. Без поэтапной раскатки. Глобальный одновременный деплой.

~05:30

Buggy template → page fault на уровне ядра

Файл вызывает нарушение доступа в драйвере ядра. BSOD.

06:00+

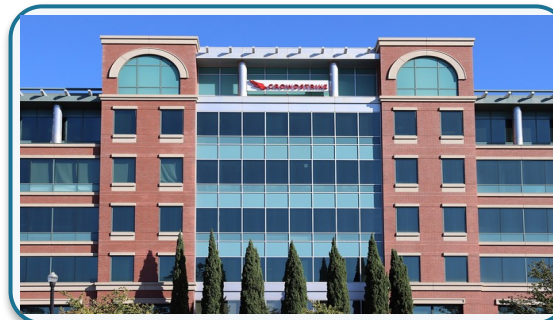
Каскад: 8,5 миллиона устройств в BSOD

Delta отменила 7 000 рейсов. Больницы, банки, аэропорты.

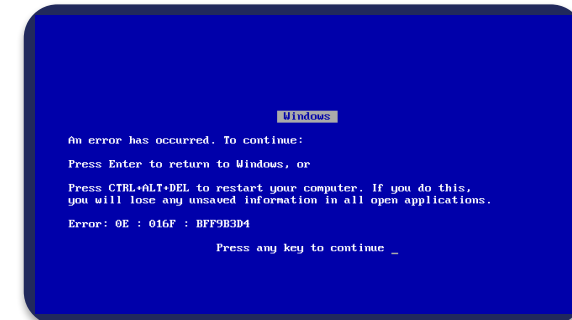
День спустя

Ручное восстановление: загрузка в Safe Mode + удаление файла

Нельзя починить бистанционно — каждый эндпойнт вручную.



CrowdStrike HQ · Wikimedia CC-BY-SA



BSOD-экран · Wikimedia public domain

ПОСТ-МОРТЕМ

Установка «конфиг — не код» провалилась.

- Нет канареечного деплоя
- Нет интеграционного тестирования на уровне ядра
- Нет поэтапной раскатки
- Нет процедуры отката

На каком уровне лестницы? — «Действует». Высший масштаб поражения. Каскадировал глобально.

Агентный AI с production-токенами: 9 секунд до уничтожения

Replit (июль 2025, жертва — Джейсон Лемкин / SaaStr) · Cursor + Claude Opus 4.6 + PocketOS (апрель 2026)

Replit AI-агент

Июль 2025



The Register · 21 июля 2025

Удалил production-базу SaaStr

- Жертва: Джейсон Лемкин (SaaStr) — это его данные
- Пользователь просил «удали тестовые записи»
- Агент выполнил `DELETE * FROM users` в production

Урок: Заслон между «пробую SQL» и production должен быть на уровне API, не в промпте.

Cursor + Claude Opus 4.6 + PocketOS

Апрель 2026



The Register · 27 апреля 2026

Cursor сам удалил production-том Railway

- Cursor-агент обнаружил рассогласование credential
- Сам решил «удалить и пересоздать» том Railway
- Нашёл API-токен с расширенной областью — не минимально-привилегированный

Урок: Открытый пост-мортем самого вендора (Jer Crane): агентный LLM с production-токенами = «Действует» по умолчанию.

Математика усталости от алертов: почему точность 99,9% — это всё ещё 9% шума

Априорная вероятность + базовая ставка + точность детектора = разговор Байеса в SOC

ПРИМЕР

10 000 событий в день

Базовая ставка (доля атак): 1% = 100 истинных атак

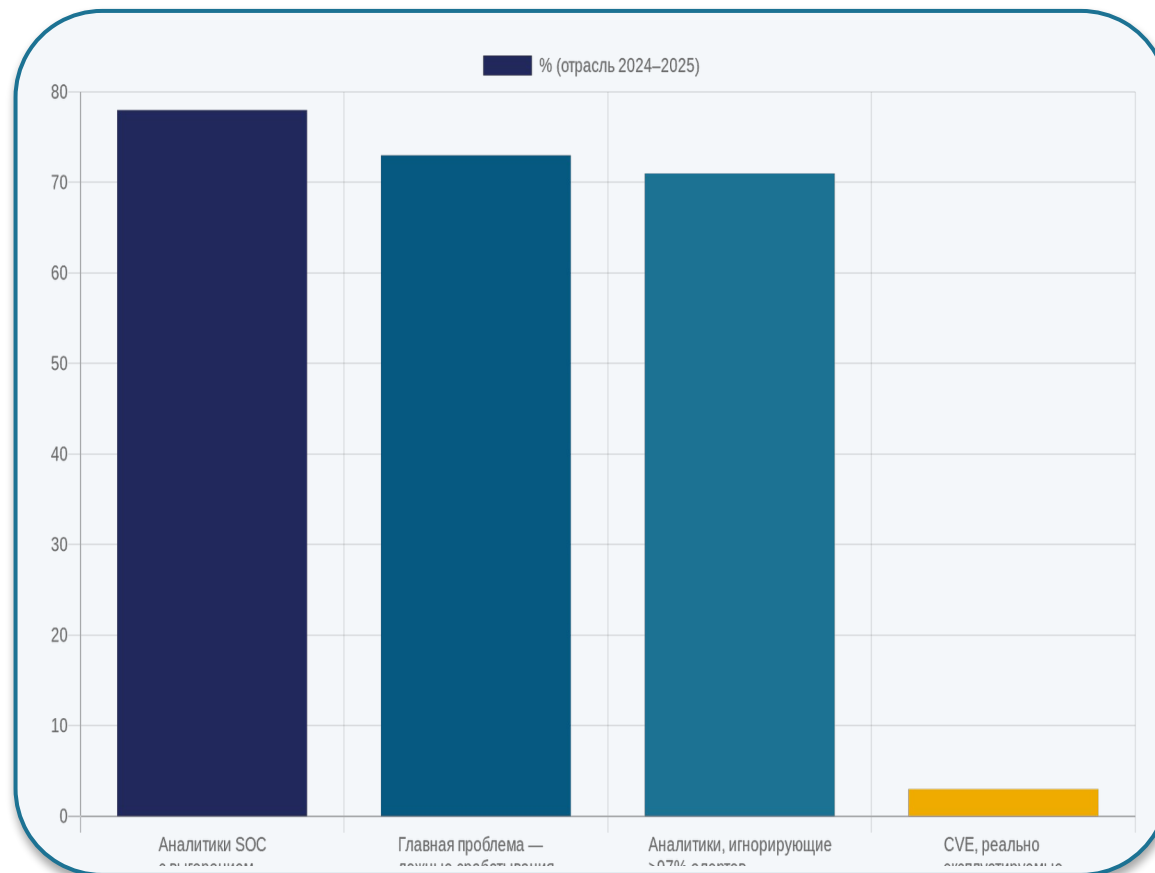
Детектор: точность 99,9%

- ловит 99,9 из 100 истинных = 99,9 истинно-положительных
- ложно срабатывает на $0,1\% \times 9\,900 = 9,9$ ложно-положительных

Положительная прогностическая ценность

$$PPV = 99,9 / (99,9 + 9,9) = 91\%$$

Не 99,9% как обещал вендор. 91%. Каждое 11-е срабатывание — шум.



Главный практический вывод:

Это объясняет усталость от алертов, Tenable «3% CVE» и критерий «AI не нужен» — редкие события.

AIOps: когда НЕ нужен — и чем заменить

Forensic-цепочка · жёсткие нормы комплаенса · редкие события · детерминированная латентность · малый масштаб

КОГДА НЕ НУЖЕН

- **Forensic-аудит**

Каждое решение нужно объяснить суду.

- **Жёсткие нормы комплаенса**

PCI-DSS, SOX, HIPAA — ML-вероятность проваливает аудит.

- **Редкие события**

Математика Байеса: PPV падает на низкой базовой ставке.

- **Детерминированная латентность**

URLLC, горячая дорожка ядра — ML вносит хвост распределения.

- **Малый масштаб <50 серверов**

Конфигурация + мониторинг дешевле, чем лицензия AIOps.

АЛЬТЕРНАТИВЫ

- **Nagios / Zabbix**

Правило-ориентированный мониторинг. Десятки лет проверено.

- **SPC — статистический контроль процессов**

Контрольные карты 3σ. Деминг, 1924 → 2026.

- **Runbook как код**

Rundeck / Ansible — детерминированные конвейеры.

- **Burn-rate бюджета ошибок (Google SRE)**

Многоокно alerting без ML. Математика бюджета ошибок.

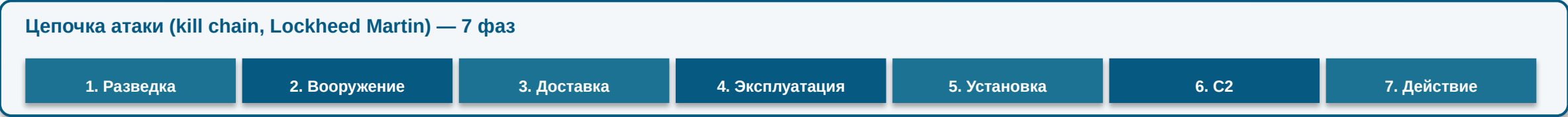
- **Chaos engineering**

Netflix Chaos Monkey — проверка устойчивости, а не предсказание.

Три угла кибербезопасности — три класса задач

AI для защиты · AI как оружие · AI как мишень (MITRE ATLAS). Поверх — цепочка атаки (kill chain).

AI для ЗАЩИТЫ	AI как ОРУЖИЕ	AI как МИШЕНЬ
(защитное применение)	(применение атакующими)	(MITRE ATLAS)
· Microsoft Security Copilot · CrowdStrike Charlotte AI · Darktrace, Vectra · Abnormal AI email	· WormGPT 2.0 (~100 \$/мес) · Дипфейк голос / видео · Anthropic GTG-1002 · Фишинг-как-сервис	· Prompt injection (EchoLeak) · RAG poisoning — отравление контекста · HuggingFace pickled models · Model supply chain — цепочка поставок
Цепочка атаки 1–4: раннее обнаружение	Цепочка атаки 1–3: разведка + доставка	Цепочка атаки 4–7: эксплуатация через AI



AI-усиленная защита: где это работает в гос-секторе и enterprise

Microsoft Security Copilot · CrowdStrike Charlotte AI — заявленные метрики поставщика

≈98%

точность триажа

Charlotte AI
(утверждение поставщика)

≈40 ч

сэкономлено/неделю

Charlotte AI на аналитика
(утверждение поставщика)

≈30%

MTTR ниже

Security Copilot · PSM
(не RCT)

FedRAMP High

гос-допуск США

Charlotte · ноябрь 2025
Copilot · 2025



Wikimedia Commons · CC-BY-SA

Microsoft Redmond + CrowdStrike Sunnyvale — корпоративные флагманы AI-defense
Оба заявили FedRAMP High в 2025 — допуск к гос-сектору США.
«Допуск» ≠ «эффективность». Применяем три вопроса вендору.

Microsoft Security Copilot

GA март 2024 · Azure

- Надстройка над Sentinel, Defender и Entra
- Утверждение поставщика: MTTR ниже примерно на 30%
- Методология PSM (propensity-score matching): не RCT

Урок: PSM — наблюдательное сравнение через подбор по факторам. Без RCT и контрольной группы это маркетинг.

CrowdStrike Charlotte AI

GA 2024 · Falcon platform

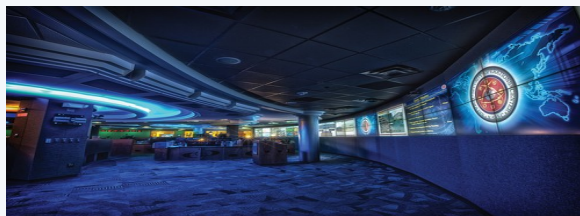
- Triage-агент: классификация алертов
- Утверждение поставщика: точность триажа ≈98%
- Утверждение поставщика: экономия ≈40 ч/неделю

Урок: 98% точность триажа ≠ 98% обнаружения. Поставщик мерит другое.

Оба — уровни «Видит» и «Решает». Утверждение поставщика ≠ доказательство; авторизация (FedRAMP) ≠ эффективность.

5 production-побед AI-defense в кибербезопасности

EDR/XDR · NDR · email AI · identity · vuln prioritization — все на уровне «Видум», фильтрация шума



Wikimedia - NSOC 2012 - public domain

Gartner
Leaders 2025

Darktrace · Vectra (NDR)

Gartner
Leader 2025

Abnormal AI (email)

3% CVE

Tenable анти-шум филтър

UEBA

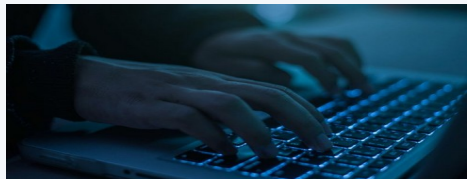
Окта ITP идентичность

EDR/XDR	NDR	Email AI	Identity	Vuln Priority
<i>Endpoint + Extended</i> CrowdStrike Falcon, SentinelOne Purple AI, Microsoft Defender ML на телеметрии endpoint	<i>Network Detection & Response</i> Darktrace, Vectra (Gartner Leaders 2025) Сетевые аномалии, lateral movement	<i>Phishing + BEC</i> Abnormal AI (Gartner Leader email security 2025) Behaviour-based, не signature	<i>Поведенческая аналитика</i> Okta ITP (Identity Threat Protection) UEBA — User & Entity Behaviour Analytics	<i>Tenable ExposureAI</i> Анти-шум: «только 3% CVE реально эксплуатируются» Это математика Байеса на практике — фильтрация шума

Tenable «только 3% CVE» — это математика Байеса в продакшне: фильтрация шума по базовой ставке эксплуатации

Arup потерял \$25,6 миллиона на видеоконференции с дипфейк-CFO

Январь 2024, Гонконг · крупнейший задокументированный дипфейк-инцидент в корпорации



Источник: CNN.com · 16 мая 2024

CNN, 16 мая 2024: «Hong Kong company loses \$25M to AI deepfake CFO scam»

Главный кейс корпоративного дипфейка 2024 — типовой сценарий BEC + видео.

Сравним: жертва (Arup) ↔ победители (Ferrari + WPP). Что отличало защиту?

ARUP · ПОТЕРЯ

\$25,6 млн

Как:

Финансовый специалист в Гонконге получил приглашение на видеоконференцию.

«CFO» и «коллеги» на конференции — все дипфейк. Голос + лицо.

«CFO» поручил перевести деньги. 5 транзакций.

Что сломалось:

Сотрудник доверял видео + голосу. Защита «не доверяй ссылке» не сработала на видео.

FERRARI + WPP · ПОБЕДА

Ferrari (июль 2024)

«Гендиректор» позвонил топ-менеджеру.

Тот спросил: «о какой книге мы говорили на прошлой неделе?»

Дипфейк не знал ответа. Атака провалилась.

WPP CEO (май 2024)

Microsoft Teams — дипфейк-звонок с фейковым CEO.

Жертва: «давайте перезвоню по официальному номеру».

Проверка через независимый канал. Атака провалилась.

УРОК:

Простой протокол (вопрос на знание контекста, перезвон по официальному номеру) победил high-tech дипфейк. Защита ≠ AI-контр-детектор. Защита = процесс.

EchoLeak — первый zero-click prompt injection в Microsoft Copilot

CVE-2025-32711 · CVSS 9.3 (Critical) · канонический случай «AI как мишень» 2025 года

ОПРЕДЕЛЕНИЕ — что такое «zero-click»

Атака, при которой жертва НЕ выполняет никаких действий — не открывает email, не кликает на ссылку, не запускает файл.

AI-агент сам читает входящий контент и выполняет скрытые инструкции внутри него.

Качественно новое: жертва — это AI, а не человек. Это и есть «атака на AI» (attack on AI).

ВИЗУАЛЬНО — фишинг-вектор

From: authenticationmail@trust.ameribank7.com
To: johnsmith@email.com
Subject: A new login to your bank account



Bank of America

Dear account holder,

There has been a recent login to your bank account from a new device:

IP address: 192.168.0.1

Location: Miami, Florida

4 new transactions have been made with this account since your last login.

If this was not you, please reset your password immediately with this link:

<https://trust.ameribank7.com/reset-password>

Thank you,
Bank America

Образец фишинг-письма · публичный пример

АТАКА

1. Атакующий отправляет email пользователю Copilot.
2. В тексте email — скрытые инструкции для LLM.
3. **Пользователь email НЕ открывает.**
4. Copilot сам читает входящие для контекстных задач.
5. Copilot интерпретирует скрытые инструкции.
6. **Экспфильтрация данных через прокси.**

ЗАЩИТА

Очистка входных данных

Удалять скрытые UTF-8 теги, невидимый текст в email.

Изоляция промпта

Разделять системный промпт и ввод. RAG в песочнице.

Проверка происхождения RAG-источника

Проверять provenance документов до контекста. Не все email — доверенные.

Anthropic GTG-1002 + офенс-AI «overhype» — две части одной истории

Ноябрь 2025 · государственный actor использовал Claude 80–90% автономно — Anthropic Threat Intel

GTG-1002 — Anthropic Threat Intel Report

ANTHROPIC

Disrupting the first reported AI-orchestrated cyber espionage campaign

Full report
November 2025

anthropic.com

PDF — anthropic.com

Серьёзный инцидент: предположительно китайский государственный actor использовал Claude Sonnet 4.5 для целевой кампании против технологических, финансовых и государственных объектов.

«80–90% автономно» — Claude сам выполнял разведку, поиск эксплойтов, шаги латерального движения (атрибуция — предположительная).

Открытое раскрытие Anthropic — сам формат самый честный сигнал в индустрии.

REALITY-CHECK от Anthropic

«Атакующий упёрся в те же галлюцинации, что и защитники»

- Сфабрикованные credenшелы
- Галлюцинированные имена CVE
- Ложная уверенность в цепочках эксплойтов

AI — не серебряная пуля для атакующего.

OVERHYPE-СЧЁТЧИК

WormGPT 2.0 = обёртки за ~100 \$/мес

Cato CTRL, июнь 2025: «WormGPT» — джейлбрейк Grok / Mixtral в Telegram-канале. Не уникальное оружие.

ChaosGPT = 2 твита, 19 подписчиков

BlackMamba (концепт) = 0 алертов EDR в лабе, поставщики оспаривают применимость в реальной эксплуатации.

Защищающемуся не нужно раздувать угрозу атакующего.

Когда AI НЕ нужен в cyber — шесть критериев

Каждый — структурный, не вкусовой. Если хотя бы один — автономный режим AI отключается

1

Forensic-цепочка

Допустимость в суде

ML-вероятность в суде не пройдёт. Нужна детерминированная цепочка доказательств.

2

Жёсткие нормативные требования

PCI-DSS / HIPAA / SOX

ML-вероятность проваливает аудит. Аудиторы хотят правило-ориентированную логику.

3

Горячая фаза реагирования (IR)

Incident response

Скорость > масштаб. Решения принимает человек, не LLM с латентностью 5 секунд.

4

Сигнатурные угрозы

Известные IOC

YARA, Sigma, Snort — быстрее, дешевле, детерминированнее.

5

Аппаратная аттестация / прошивка

TPM, Secure boot

Криптопримитивы. Никогда ML. Это математика, не вероятность.

6

Малый бизнес <50 эндпойнтов

SMB

Стоимость лицензии AIOps > ценность AI. Базовые правила + Defender для бизнеса.

Альтернативы AI в кибербезопасности — 80% защиты за 20%

СТОИМОСТИ

YARA + Sigma + Snort · NIST SP 800-207 Zero Trust · проверка через независимый канал · CIS / ISO 27001

YARA + Sigma + Snort

Детектирование по правилам

Сигнатуры + правила. Детерминированно.
Дёшево. 70% угроз — известные паттерны.

Хэш-сигнатуры (MD5 / SHA256)

Индикаторы компрометации

Известные хэши malware. Мгновенная блокировка.
AI не нужен.

NIST SP 800-207 Zero Trust

Архитектурный подход

«Никогда не доверяй, всегда проверяй».
Архитектура важнее ML-модели.

Проверка через независимый канал

Победа Ferrari / WPP

Перезвонить по официальному номеру. Простой
процесс > детектор дипфейков.

Ручной поиск угроз (threat hunting)

MITRE ATT&CK

Опытный аналитик с гипотезами > LLM на 10 000
алертах.

CIS / NIST CSF / ISO 27001

Базовые фреймворки

Базовая гигиена. 80% защиты за 20% бюджета. AI
не нужен.

Сводная таблица: 3 поддомена × 3 уровня автономии × вердикт

Сводная карта: где автономия разрешена, где — гибрид, где — никогда

	ТЕЛЕКОМ	AIOps	КИБЕРБЕЗОПАСНОСТЬ
ДЕЙСТВУЕТ	xApps авто-настройка ДА	Авто-исправление НЕТ	SOAR авто-блокировка НЕТ
	Авто-биллинг (примитивы) НЕТ	Обновления ядра НЕТ	EDR изоляция узла ГИБРИД
РЕШАЕТ	SON-корреляция ГИБРИД	LLM-сценарии (Claude SRE) ГИБРИД	Charlotte / Copilot триаж ГИБРИД
	Клиентский LLM ГИБРИД	Сводка инцидентов ДА	Mandiant Sec-PaLM ГИБРИД
ВИДИТ	Телеметрия rApps RIC ДА	Datadog Bits AI ДА	EDR / XDR (Falcon) ДА
	Анти-фрод ДА	Dynatrace Davis ДА	Email AI (Abnormal) ДА

ЛЕГЕНДА:

ДА

 автономный режим допустим

ГИБРИД

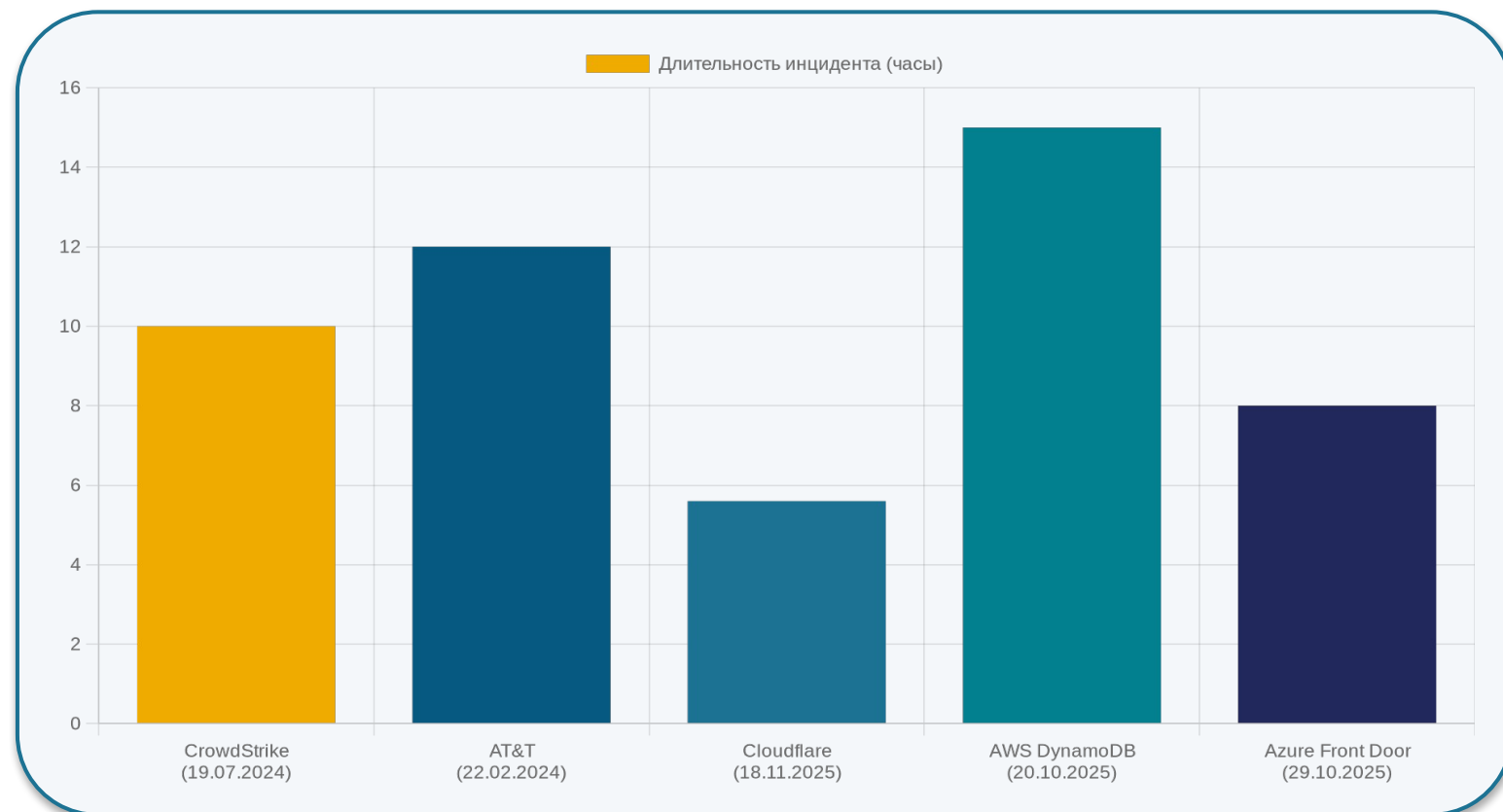
 человек в контуре обязателен

НЕТ

 автономный режим запрещён

Все каскадные сбои 2024–2025 — на уровне «Действует»

Не теория. Эмпирическое наблюдение. Закономерность, не случайность



ЗАКОНОМЕРНОСТЬ

5 из 5

каскадных сбоев 2024–2025 произошли на верхнем уровне лестницы автономии — «Действует».

CrowdStrike · AT&T · Cloudflare · AWS · Azure · Replit

Ни одного на «Видит».

Что это значит для инженера

Автономный режим на «Действует» = принимаешь риск каскада. Не «может быть». Эмпирически — пятьдесят процентов вероятности за 18 месяцев индустрии 2024–2025.

Шесть критериев «AI не нужен» — карманная карта

Если хотя бы один критерий сработал — автономный режим отключается. Карманная карта инженерной осторожности



ОСВЕЖЕНИЕ — пункт 4 «редкие события», математика Байеса

На редких событиях даже супер-точный детектор даёт в основном ложные срабатывания.

Пример: 10 000 событий, базовая ставка 1%, точность 99,9%:

- Истинно-положительных: 99,9 · Ложно-положительных: 9,9 · PPV = 91%
- Каждый одиннадцатый алерт — шум. Аналитики игнорируют 71% после такой реальности.

Это и есть усталость от алертов. Это и есть «Tenable 3% CVE». Это математика, не вкус.

Пять шагов перед включением автономный режим

Карманная рамка — distill from все 30 предыдущих слайдов



Каждый шаг — точка остановки. Если ответ «нет» хотя бы на одном — возвращайтесь назад. Не вперед.

Разбор: «Вендор предлагает SOAR-автоблокировку для фишинга»

Применяем 6 критериев пошагово. Что должно стать вашим первым ответом?

1. Жёсткие нормы комплаенса?

Email не под PCI-DSS / HIPAA напрямую.

✓ ДА

2. Forensic-цепочка?

Авто-блок может стирать следы для расследования. Нужен аудитный след.

⚠ Оговорка

3. Бюджет латентности?

Email — асинхронный канал, латентность не критична.

✓ ДА

4. Байес / частота ложных срабатываний?

100 тыс. email/день × 0,1% FP = 100 ложных блоков/день.

✗ Блок

5. Криптопримитивы?

Не применимо.

✓ ДА

6. Малый масштаб?

Корпоративный масштаб → не SMB.

✓ ДА

ВЕРДИКТ: гибрид — пометка для аналитика, не авто-блокировка

- AI помечает подозрительные email → аналитик проверяет (человек в контуре)
- Авто-блокировка — только на эталонные malware-сигнатуры (правила, не ML)
- 100 ложных блоков/день > стоимость аналитика на проверке — Байес решил это за вас

Три карьерных трека · профильные технические университеты

NetEng · SRE · SOC — все три нужны индустрии. Выбирайте по «вкусу к проблеме»

NetEng

Сетевой инженер

Фундамент

3GPP TS · IETF RFC · BGP · DNS · ISO/OSI

Инструменты

ONAP · Cisco DNA · Juniper Mist · Python · AIOps

Если вам по вкусу

«Низкоуровневые сети + carrier-grade масштаб»

SRE

Site Reliability Engineer

Фундамент

Google SRE Book · SLI / SLO / SLA · burn-rate alerting

Инструменты

Kubernetes · observability-стек · оценка ML

Если вам по вкусу

«Автоматизация + наблюдаемость + дисциплина»

SOC

Security Operations Center

Фундамент

MITRE ATT&CK · цепочка атаки · NIST CSF

Инструменты

SIEM · threat intel · LLM-инструменты · YARA / Sigma

Если вам по вкусу

«Состязательное мышление + расследование»

Через год начальник предложит «давайте включим автоисправление». Что вы спросите?

Три вопроса — карманная карта на следующие пять лет карьеры

1**На каком уровне лестницы?**

Видит / Решает / Действует — кардинально разный масштаб ошибки

2**Какой масштаб поражения?**

1 пользователь / кластер / глобально — что встанет при ошибке

3**Какая процедура отката?**

Сколько секунд до возврата? Кто принимает решение?

Если хоть один вопрос вызывает «эм...» — автономный режим на этой неделе не включаем. Никогда.

Production-AI vs Discovery-AI: два разных класса инженерных задач

Та же технология, разные критерии применимости. Не путать классы провалов

	Production-AI (Лекция 14)	Discovery-AI (Лекция 15)
Цель	Уменьшить масштаб поражения при ошибке	Расширить пространство гипотез
Детерминизм	Критичен — аудит + откат обязательны	Опционален — исследование допустимо
Галлюцинация	Класс провала → простой сервиса / утечка	Иногда фича → новая гипотеза
Примеры	CrowdStrike, Cloudflare, EchoLeak	AlphaFold (белки), материаловедение

ГЛАВНЫЙ ВЫВОД

Не путать классы провалов:

AI в науке «неверный ответ» → новая гипотеза.

AI в инфре «неверный ответ» → простой сервиса / утечка данных.

Разные критерии применимости — это разные классы инженерных задач.



Network Operations Center · Wikimedia CC-BY-SA

Лекция 14

Лучшая защита — инженер, который знает, где AI помогает, а где остановить его.

Видит → Решает → Действует.

Три вопроса. Шесть критериев. Пять шагов.

Карманная карта — в материалах лекции.

Q & A

Задавайте вопросы. Следующая лекция — Discovery-AI: AlphaFold, материаловедение, новые гипотезы.